

1. Protección de Datos

Esta unidad se mira desde la perspectiva del **CISO** (*Chief Information Security Officer*), el responsable de velar por la seguridad de la información de la empresa (con implicancias legales si hay un incidente severo). Se aplican todos los principios ya vistos para proteger la **CIA** (Confidencialidad, Integridad y Disponibilidad) de los datos.

1.1. El problema y el ciclo de protección

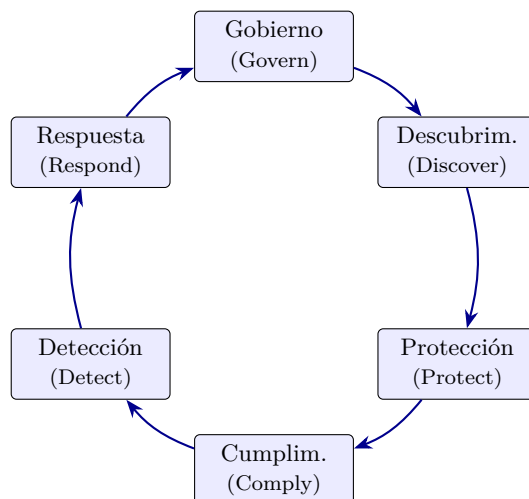
El problema motivador: en una empresa se define una política de protección de datos personales (ej. “un empleado no puede ver los sueldos de otro”). Los **controles de acceso son parte de la solución pero no son suficientes**: un mismo dato (un sueldo) fluye por RR.HH. → App → Excel → Email → nube, con backups en el medio. Hay que protegerlo en todo su recorrido.

Definición: Dato personal

Todo lo que permite **identificar a una persona** solamente por ese mismo dato: nombre y apellido, dirección de mail, número de documento, domicilio. Dentro de la organización hay además datos **sensibles** (ej. el sueldo) que no se quieren divulgar.

Ciclo de protección de la información (es un ciclo, vuelve a empezar):

1. **Gobierno (Govern)**: gestión, toma de decisiones.
2. **Descubrimiento (Discover)**: qué datos hay en el universo de la organización.
3. **Protección (Protect)**: cómo y qué datos protegemos (no todos son sensibles).
4. **Cumplimiento (Comply)**: asegurar que la protección efectivamente ocurre.
5. **Detección (Detect)**: detectar filtraciones / *breaches*.
6. **Respuesta (Respond)**: responder ante filtraciones y evitar que se repitan.

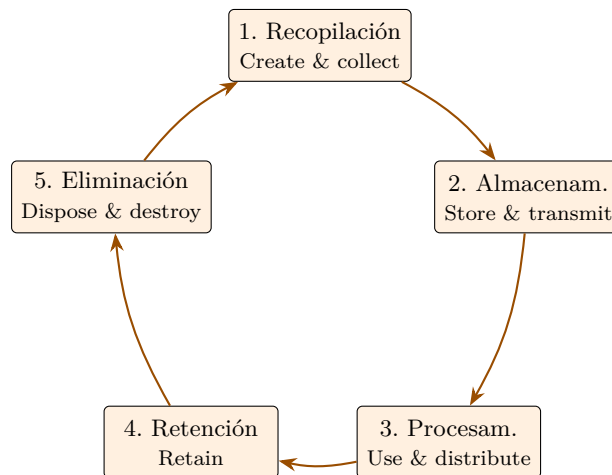


Ciclo de la protección de la información: es un ciclo, al terminar Respond se vuelve a Govern.

1.1.1. Data Governance

Son **todas las tareas para asegurar que los datos estén seguros, privados, íntegros y disponibles**. Incluye las medidas que toman las **personas**, los **procesos** que siguen y la **tecnología** que los respalda durante el **ciclo de vida de los datos**. Define los roles dentro de la organización. Establece estándares internos (**políticas de datos**) sobre: recopilación, almacenamiento, procesamiento, retención y eliminación.

Data Life Cycle (PwC): (1) Create & collect → (2) Store & transmit → (3) Use & distribute → (4) Retain → (5) Dispose and destroy (al vencer el período de retención).

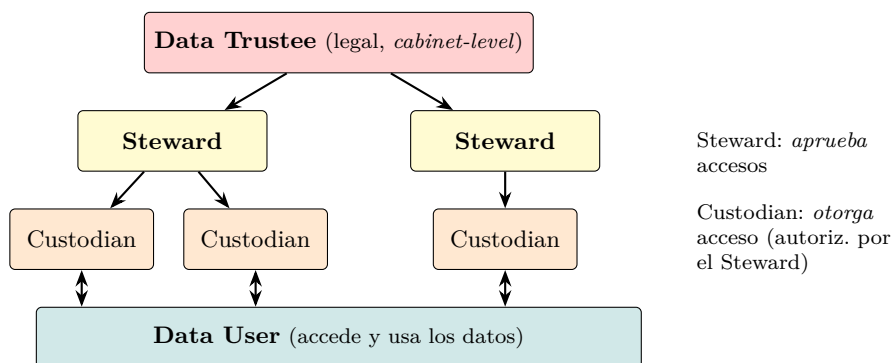


Ciclo de vida del dato (PwC): la eliminación ocurre al vencer el período de retención y el ciclo se reinicia.

1.1.2. Data Roles (jerarquía)

- **Data Trustee:** posición estratégica/*cabinet-level*, responsable **legalmente** de los datos de su unidad.
- **Data Steward:** responsable interno que **aprueba accesos** a los datos dentro de su dominio.
- **Data Custodian:** autorizado por un Steward a **otorgar acceso** a los usuarios dentro del dominio del Steward.
- **Data User:** quien efectivamente **accede** y usa los datos.

A medida que se baja en la jerarquía, el dominio de datos manejado es cada vez más chico.



Roles del dato: al bajar en la jerarquía el dominio de datos manejado es cada vez más chico.

1.2. Marco legal y regulaciones

! Importante — remarcado en clase

La distinción más preguntable: la **Ley argentina 25.326** regula las bases de datos (públicas y privadas). El **Derecho al Olvido** lo regula el **GDPR europeo**, NO la ley argentina.

1.2.1. Regulación argentina: Ley 25.326

Definición: Ley 25.326 – Protección de Datos Personales

Ley argentina (de los años 80–90). Aplica a todo sistema que opera en Argentina.

- **Art. 1 (Objeto):** protección integral de los datos personales asentados en archivos, registros, bancos de datos u otros medios técnicos de tratamiento, **sean públicos**

o **privados**, para garantizar el derecho al honor y a la intimidad de las personas (conforme art. 43, párr. 3 de la Constitución).

- **Art. 9 (Seguridad de los datos):** el responsable/usuario del archivo debe adoptar las medidas técnicas y organizativas necesarias para garantizar seguridad y confidencialidad, evitando adulteración, pérdida, consulta o tratamiento no autorizado, y permitiendo detectar desviaciones. Queda **prohibido** registrar datos en bancos que no reúnan condiciones técnicas de integridad y seguridad.

! Importante — remarcado en clase

La ley **no especifica una tecnología** concreta. Esto es a propósito (“para bien”): la generalidad hace que la ley **siga siendo aplicable hoy** pese a ser de hace décadas. Implica también que las personas pueden **ver, modificar e incluso pedir el borrado** de sus datos (hábeas data).

Hábeas data vs. hábeas corpus. El **hábeas data** es el derecho por el cual sos dueño de tus datos: podés pedir verlos, rectificarlos o que se borren (a diferencia del *hábeas corpus*, que protege la libertad física de la persona). Empresas como Facebook/Twitter permiten descargar todo tu historial y borrar la cuenta.

1.2.2. Regulaciones internacionales

Norma	Descripción
HIPAA (1996)	<i>Health Insurance Portability and Accountability Act</i> . Protección de datos de salud (PHI/PII). Surge la anonimización de datos (operar sobre historias clínicas sin saber de quién son).
GDPR (2018)	<i>General Data Protection Regulation</i> (Unión Europea). La más conocida. Aplica aunque el sistema esté en Argentina si hay usuarios/infraestructura en la UE. Pide consentimiento explícito (de ahí los <i>banners</i> de cookies). Regula el Derecho al Olvido .
PCI-DSS	<i>Payment Card Industry Data Security Standard</i> . Tarjetas de crédito. Acotó la cantidad de datos a proteger (número, titular, vencimiento, código de seguridad/CVV, banda magnética). Introdujo la tokenización .
SOX (2002)	<i>Sarbanes-Oxley Act</i> (ley federal de EE.UU.). Empresas que cotizan en bolsa; exige transparencia. Retención de auditoría 7 años .
FFIEC	<i>Assessment Tool</i> (framework, hoy en desuso).
FDA Cybersecurity	Ciberseguridad en dispositivos médicos.

! Importante — remarcado en clase

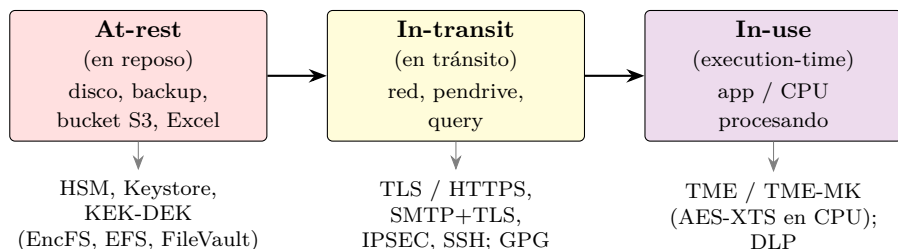
El gran aporte de **PCI-DSS** (“Blue Print”): a la hora de proteger datos hay que **acotar la cantidad de datos en base a su criticidad**. No proteger todo por igual, sino concentrarse en lo crítico.

Tokenización (PCI-DSS). Los datos críticos de la tarjeta se guardan “bajo 7 llaves” en una base recontra protegida; el sistema opera con un **token** que apunta a la tarjeta. Si se filtra el token, no tiene valor por sí solo: habría que ir a buscar los datos reales a la base ultra-protegida.

1.3. Estados del dato y encriptación

Un mismo dato puede estar en distintos **estados**; las regulaciones definen lineamientos para cada uno:

- **En reposo (at-rest)**: el dato está quieto, no se procesa ni se mueve (base de datos, backup, Excel, bucket S3).
- **En tránsito / movimiento (in-motion / in-transit)**: se mueve de una ubicación o estado a otro (a través de la red, un pendrive, una query).
- **En uso (in-use)**: está siendo procesado/usado por una aplicación o CPU.
- **En memoria**: caso particular; puede verse como *at-rest* en memoria esperando a la CPU, o *in-transit* entre el bus de I/O y la CPU.



Mismo dato en distintos estados y la técnica de cifrado en cada uno.

1.3.1. Enforcement (Compiler-time)

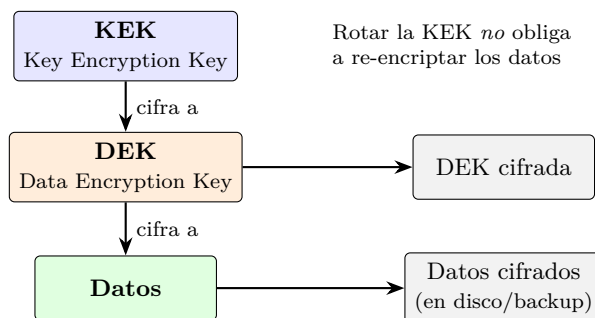
Asegura que el código cumpla políticas de seguridad **antes** de ejecutarse, vía **análisis estático de código** en la compilación (ej. detectar que se imprimen contraseñas/secretos). El compilador puede asegurar que datos confidenciales no se filtren a zonas de memoria de menor seguridad. Ejemplo: `GuardedString` de Java (guarda el string **encriptado** en memoria; un `String` clásico se ve en texto plano inspeccionando el proceso).

1.3.2. Encriptación at-rest

Objetivo: proteger datos inactivos (disco, pendrive, etc.). Mecanismos:

- **HSM** (*Hardware Security Module*, FIPS 1–4): hardware **anti-tampering** que guarda secretos (ej. claves simétricas) y ofrece las operaciones de cifrado/descifrado **sin exponer la clave**.
- **Keystore**: software que guarda todas las claves encriptadas con una clave **máster**.
- **Esquema KEK-DEK (encriptación por capas)**:
 - **DEK** = *Data Encryption Key* (cifra los datos).
 - **KEK** = *Key Encryption Key* (cifra la DEK).

Más seguro y flexible: se puede **rotar la KEK** sin re-encriptar los datos (la DEK no cambia). Más difícil de administrar (segunda capa). Ejemplos: EncFS/Loop-AES, EFS (Windows), FileVault (Mac OS X). Problemas asociados: *Data Remanence* y *Secure Deletion*.



Jerarquía de claves (envelope encryption): la KEK cifra la DEK y la DEK cifra los datos. Se almacenan la DEK cifrada y los datos cifrados.

At-rest en la nube. La nube es infraestructura de terceros. Espectro de opciones (de mayor control/menor costo a mayor eficiencia operativa/mayor costo):

Opción	Quién controla las claves
Own Encryption	Encriptación del lado del proceso antes de almacenar. Independiente del proveedor.
Hold Your Own Keys (HYOK)	El cliente gestiona las claves, posee las privadas y decide la rotación.
Bring Your Own Keys (BYOK)	El cliente trae sus claves.
Customer Managed Keys	El cliente decide rotación y puede encriptar lo que desee, pero no accede a las claves privadas.
Service Managed Keys	El proveedor decide la rotación; el cliente no accede a las claves ni las usa para otros contenidos. Máxima eficiencia, mínimo control.

Ojo con la ubicación de los datos: distintas regiones/países aplican distintas regulaciones.

1.3.3. Encriptación in-transit

- Encriptar **antes** de mover (ej. cifrar un archivo con GPG antes de mandarlo por mail).
- Usar **protocolos de transporte** que aseguren cifrado: TLS (HTTPS), SMTP sobre TLS, IPSEC, SSH. (Acuerdan clave por asimétrica y luego cifran todo el tráfico de forma simétrica.)

1.3.4. Enforcement (Execution-time)

Técnica más usada para monitorear/controlar cómo se transmite la información entre componentes. Se implementa a nivel **aplicativo** (buenos principios de seguridad, no exponer secretos) o a nivel de **infraestructura** con **DLP** (*Data Loss Prevention*). Requiere entender el movimiento de datos (entre procesos, niveles de seguridad o estados).

1.3.5. Encriptación en memoria (TME / TME-MK)

En ambientes con múltiples VMs accediendo a la misma memoria hay riesgo de acceder a información confidencial. Intel (y otros) implementaron en hardware:

- **TME** (*Total Memory Encryption*): **una sola clave** compartida por todos los procesos. La desenscriptación se hace **dentro de la CPU, antes del caché** (AES-XTS en los controladores DRAM/NVRAM).
- **TME-MK** (*Multi-Key*): **múltiples claves**, con control de acceso soportado por los registros de **VT-x** (cada VM usa un *KeyID*).

1.3.6. SoC / IoT / Embedded Security

Escenario de los más desfavorables: chips expuestos físicamente, arquitectura abierta, **debug** accesible, conectividad **wireless**, gran **escala** y **riesgo físico** (tampering). Se recomienda incluir un HSM embebido (ej. chip ATECC608A). Capas: Perception, Application, Network.

1.4. Cumplimiento, detección y respuesta

1.4.1. Comply (Cumplimiento)

“No basta con ser bueno, también hay que parecerlo.”

— dicho en clase Hay que **demostrar** (ej. ante una auditoría) que la protección efectivamente ocurre $\Rightarrow$ todo se **loguea** y queda evidencia.

Retención: guardar información que ya no es necesaria, por temas regulatorios / legales / forenses. Ejemplos: HIPAA **6 años** desde el último uso; SOX **7 años**. Algunas leyes obligan a **rotar las claves de encriptación** (ej. cada 10 años) y re-encriptar todo.

1.4.2. Detect – DLP (Data Loss Prevention)

Herramientas que ayudan a clasificar, inventariar y detectar datos en todos sus estados. **No son preventivas ni correctivas, sino DETECTIVAS:** se activan al fallar la aplicación de una política (generan alerta). Son **complejos de implementar**; hoy sus funcionalidades vienen incorporadas en productos de uso diario (pueden detectar, ej. encriptación no autorizada típica de *ransomware*).

1.4.3. Respond (Respuesta a incidentes)

Equipos dedicados con protocolo. **Primeras 24 h:** registrar fecha/hora, alertar, asegurar el lugar, **frenar la exfiltración**, documentar todo, entrevistar a los involucrados, traer equipo **forense**, notificar a las autoridades. **Más allá de 24 h:** trabajar con forenses, identificar obligaciones legales, reportar a la dirección, identificar problemas futuros y **arreglar el problema**.

! Importante — remarcado en clase

No ocultar el incidente, pero comunicar **solo lo mínimo y necesario**. Si hay regulación de datos personales de por medio, hay que informar al organismo (y, según el caso, a bancos y clientes afectados).

1.5. Encriptación Homomórfica

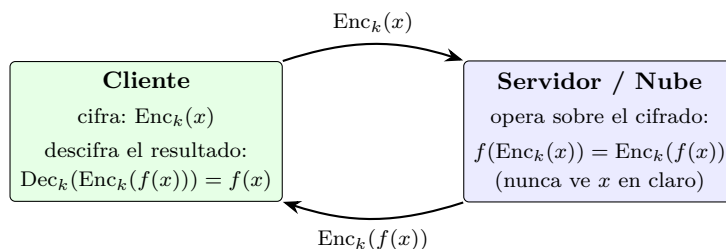
Definición: Encriptación homomórfica

Esquema de cifrado que permite **operar sobre los datos cifrados sin descifrarlos**. Formalmente, para una función f :

$$f(\text{Enc}_k(x)) = \text{Enc}_k(f(x)).$$

Es decir, operar sobre el texto cifrado y luego descifrar da el mismo resultado que operar sobre el texto plano.

Utilidad. Permite **computación en la nube preservando la privacidad**: un tercero (proveedor) puede procesar/analizar datos cifrados **sin verlos nunca** en claro. Útil cuando se quiere delegar cómputo sobre datos sensibles sin exponerlos.



Encriptación homomórfica: el cliente cifra, el servidor opera sobre el texto cifrado sin descifrarlo y el cliente descifra el resultado.

△ Cuidado — error típico

La diapositiva del teórico escribe la propiedad como $f(x) = y \Rightarrow f(\text{Enc}(x)) = f(\text{Dec}(y))$, pero la formulación conceptual correcta y la que conviene recordar es $f(\text{Enc}_k(x)) = \text{Enc}_k(f(x))$: **operar sobre lo cifrado equivale a cifrar el resultado de operar sobre lo plano.**